



NayaHR — Data Processing Agreement (DPA)

DRAFT for legal review. Working draft aligned to India's Digital Personal Data Protection Act, 2023 (**DPDP Act**). Not legal advice — have qualified Indian legal counsel finalise before use. Bracketed [...] items are facts to be filled at finalisation.

This Data Processing Agreement ("DPA") forms part of, and is subject to, the Terms of Service or other master agreement (the "**Agreement**") between:

- **NayaHR Private Limited**, [Registered address], Pune, Maharashtra, India ("**NayaHR**", the **Data Processor**); and
- the customer identified in the Agreement (the "**Customer**", the **Data Fiduciary**).

Effective date: the effective date of the Agreement.

1. Definitions

Terms used but not defined here have the meaning given in the DPDP Act, including **Data Principal**, **Data Fiduciary**, **Data Processor**, **Personal Data**, and **Processing**. "**Employee Personal Data**" means Personal Data of the Customer's employees, workers, contractors and candidates that is processed through the Service.

2. Roles of the parties

2.1 The Customer is the **Data Fiduciary** for Employee Personal Data and determines the purposes and means of its processing.

2.2 NayaHR acts as the **Data Processor** and processes Employee Personal Data **only on the Customer's documented instructions**, including as set out in this DPA and as given through the ordinary use of the Service.

2.3 The Customer is responsible for establishing a **lawful basis** for the processing (including obtaining any required consent from, and giving any required notice to, its employees), and for the accuracy of the data it provides.

3. Scope & purpose of processing

The subject-matter, nature, purpose, duration, categories of Data Principals and types of Personal Data are set out in **Annex A**.

4. NayaHR's obligations

NayaHR shall:

- (a) process Employee Personal Data only on the Customer's documented instructions, and inform the Customer if an instruction appears to infringe applicable law;
- (b) ensure persons authorised to process the data are bound by confidentiality;
- (c) implement and maintain the technical and organisational security measures described in **Annex C**;
- (d) taking into account the nature of processing, **assist the Customer** in responding to Data Principal requests (access, correction, completion, updating, erasure, grievance, nomination) received through or relating to the Service;
- (e) **notify the Customer without undue delay, and in any case no later than 72 hours**, after becoming aware of a personal data breach affecting Employee Personal Data, with the information reasonably available, and assist the Customer with its own notification obligations;
- (f) assist the Customer with security, breach-handling and any consultation with the Data Protection Board of India, taking into account the information available to NayaHR;
- (g) at the Customer's choice, **delete or return** Employee Personal Data as set out in Section 9; and
- (h) make available information reasonably necessary to demonstrate compliance with this DPA (Section 8).

5. Sub-processing

5.1 The Customer provides **general authorisation** for NayaHR to engage the sub-processors listed in **Annex B** to process Employee Personal Data.

5.2 NayaHR will impose data-protection and confidentiality obligations on each sub-processor no less protective than this DPA, and remains responsible for their performance.

5.3 NayaHR will give the Customer **reasonable prior notice** of any new or replacement sub-processor. If the Customer reasonably objects on data-protection grounds, the parties will work in good faith to resolve it; if unresolved, the Customer may terminate the affected Service.

6. Cross-border transfer & data residency

6.1 NayaHR hosts the primary customer database in **India (Mumbai)**.

6.2 Certain sub-processors (Annex B) process limited Personal Data outside India. NayaHR will only transfer Personal Data outside India in accordance with the DPDP Act and subject to appropriate contractual safeguards, and not to any country restricted by the Government of India.

7. Data Principal rights & requests

If NayaHR receives a request from a Data Principal relating to Employee Personal Data, it will, where lawful, **direct the request to the Customer** and will assist the Customer in responding, as the Customer (Data Fiduciary) is responsible for fulfilment.

8. Audit & information

NayaHR will make available to the Customer, on reasonable request and no more than once per year (unless required by a regulator or following a breach), information reasonably necessary to demonstrate compliance with this DPA, subject to confidentiality and to protecting the security and data of other customers.

9. Return & deletion

On termination or expiry of the Agreement, NayaHR will, at the Customer's choice, make Employee Personal Data available for export and then **delete it within the grace period of 30–90 days**, save to the extent retention is required by law. Backups are deleted on their ordinary cycle.

10. Liability

Each party's liability under this DPA is subject to the **limitations and exclusions of liability in the Agreement**.

11. Term

This DPA takes effect on the Agreement's effective date and continues until all Employee Personal Data has been deleted or returned in accordance with Section 9.

12. Governing law

This DPA is governed by the laws of India, with exclusive jurisdiction of the courts at **Pune, Maharashtra**. If there is a conflict between this DPA and the Agreement on data-protection matters, this DPA prevails.

Annex A — Details of processing

- **Subject-matter:** provision of the NayaHR HR & payroll Service.
- **Duration:** the term of the Agreement, plus the deletion grace period.
- **Nature & purpose:** storing and processing employee, compensation and payroll data to deliver HR, payroll and statutory computation features; generating payslips, bank payout files and statutory summaries; and providing an AI assistant.
- **Categories of Data Principals:** the Customer's employees, workers, contractors and job candidates.
- **Types of Personal Data:** identity & contact details; job and organisational data; compensation and payroll data; statutory deductions (PF, ESI, Professional Tax, TDS); and payout/statutory identifiers (bank account, IFSC, UPI ID, PAN, UAN).
- **Special note:** the Service is not intended for children's data or, unless the Customer instructs otherwise, for special/sensitive categories beyond those listed.

Annex B — Authorised sub-processors

Sub-processor	Purpose	Location
Neon	Database hosting	India (Mumbai) [CONFIRM once migrated]
Clerk	Authentication / sign-in	United States
Vercel	Application hosting / delivery	United States & global edge
Anthropic	AI assistant (API); not used to train models	United States
GoDaddy	Business email	Global

Annex C — Technical & organisational security measures

- **Tenant isolation:** PostgreSQL Row-Level Security enforced (FORCE RLS) via a database role that cannot bypass it, so one customer's data is not accessible to another.
- **Encryption in transit:** TLS for data in transit.
- **Access control:** least-privilege roles (Owner / HR Admin / Manager / Employee); invitation-only access; authentication via a dedicated provider.
- **Auditing:** audit logging of sensitive actions (e.g. role changes, payroll actions, data-detail changes).
- **Resilience & monitoring:** managed database with backups/point-in-time recovery [CONFIRM once enabled], error tracking and uptime monitoring.
- **Data minimisation for AI:** only the context necessary to fulfil a request is sent to the AI sub-processor.